Fatec
São Caetano
do Sul

Segurança em Sistemas Operacionais e Redes de Computadores II

ISG012-01 - Arquitetura de Redes Seguras: Do Perímetro à Segmentação Lógica

Objetivo da Aula

- Abrange a compreesão e a aplicação dos princípios fundamentais de arquitetura de redes seguras, distinguindo entre modelos tradicionais de perímetro e abordagens modernas como Zero Trust e Defense in Depth;
- Estabelece os fundamentos teóricos e práticos necessários para o projeto de infraestruturas de rede resilientes. O foco reside na transição de arquiteturas baseadas em perímetro fixo para modelos dinâmicos baseados em segmentação e desconfiança implícita;
- Ao compreender estes paradigmas, o aluno estará apto a identificar vulnerabilidades estruturais em redes planas(1) e propor soluções de isolamento lógico que minimizem a superfície de ataque lateral.

---

(1) Redes planas (ou flat networks) são infraestruturas de rede onde todos os dispositivos compartilham o mesmo domínio de broadcast, geralmente operando em uma única VLAN ou sub-rede IP, sem qualquer segmentação lógica ou física entre eles.

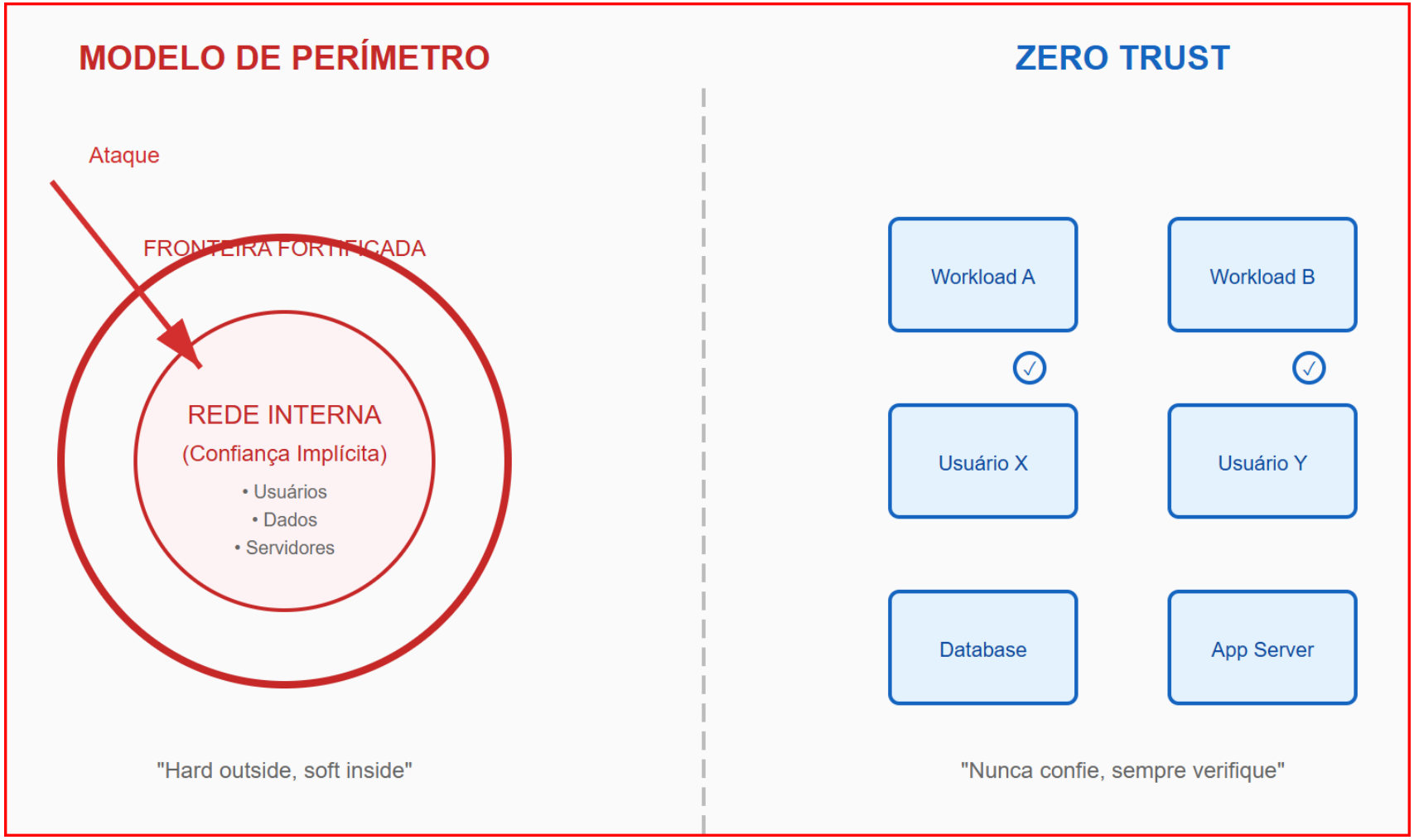
Objetivo da Aula

- Compreender a evolução histórica das arquiteturas de segurança de redes;
- Diferenciar modelos de perímetro tradicionais de abordagens modernas;
- Aplicar conceitos de Defense in Depth e Zero Trust em cenários reais;
- Projetar segmentação lógica utilizando VLANs e zonas de segurança;
- Implementar DMZs como estratégia de contenção de serviços expostos;
- Utilizar subnetting como ferramenta de microssegmentação;
- Analisar trade-offs entre complexidade e segurança em arquiteturas segmentadas.

O Modelo de Perímetro Tradicional

- A arquitetura de perímetro, predominante nas décadas de 1990 e 2000, opera sob a premissa de "castelo e fosso": recursos robustos de segurança protegem a fronteira externa, enquanto o interior da rede goza de confiança implícita;
- Este modelo presume que ameaças externas são o único vetor de risco, estabelecendo firewalls na borda como sentinelas absolutas;
- Entretanto, a mobilidade dos dispositivos, a nuvem híbrida e a sofisticação de ameaças internas tornaram este paradigma obsoleto, uma vez que um único comprometimento na borda expõe toda a rede interna.

Perímetro vs. Zero Trust



O Modelo de Perímetro Tradicional

- **Conceito Central:** "Hard outside, soft inside" – proteção concentrada na borda;
- **Limitação Crítica:** Confiança implícita em tráfego interno após autenticação inicial;
- **Vetores de Falha:** Ameaças internas, malware lateral e dispositivos BYOD[1] comprometidos;
- **Insuficiência:** Não endereça adequadamente segmentação entre sistemas críticos;
- **Legado:** Ainda presente em infraestruturas legadas, exigindo modernização gradual.

---

(1) Malware Lateral (Lateral Movement) e dispositivos BYOD são dois vetores críticos que tornam o modelo de perímetro tradicional obsoleto:

- Movimentação lateral é a técnica utilizada por atacantes para se deslocarem de um sistema comprometido inicial para outros sistemas dentro da mesma rede, expandindo seu acesso e buscando ativos de maior valor (crown jewels);
- BYOD (Bring Your Own Device) é a política que permite funcionários utilizarem dispositivos pessoais (smartphones, tablets, laptops) para acessar recursos corporativos (email, Wi-Fi, arquivos).

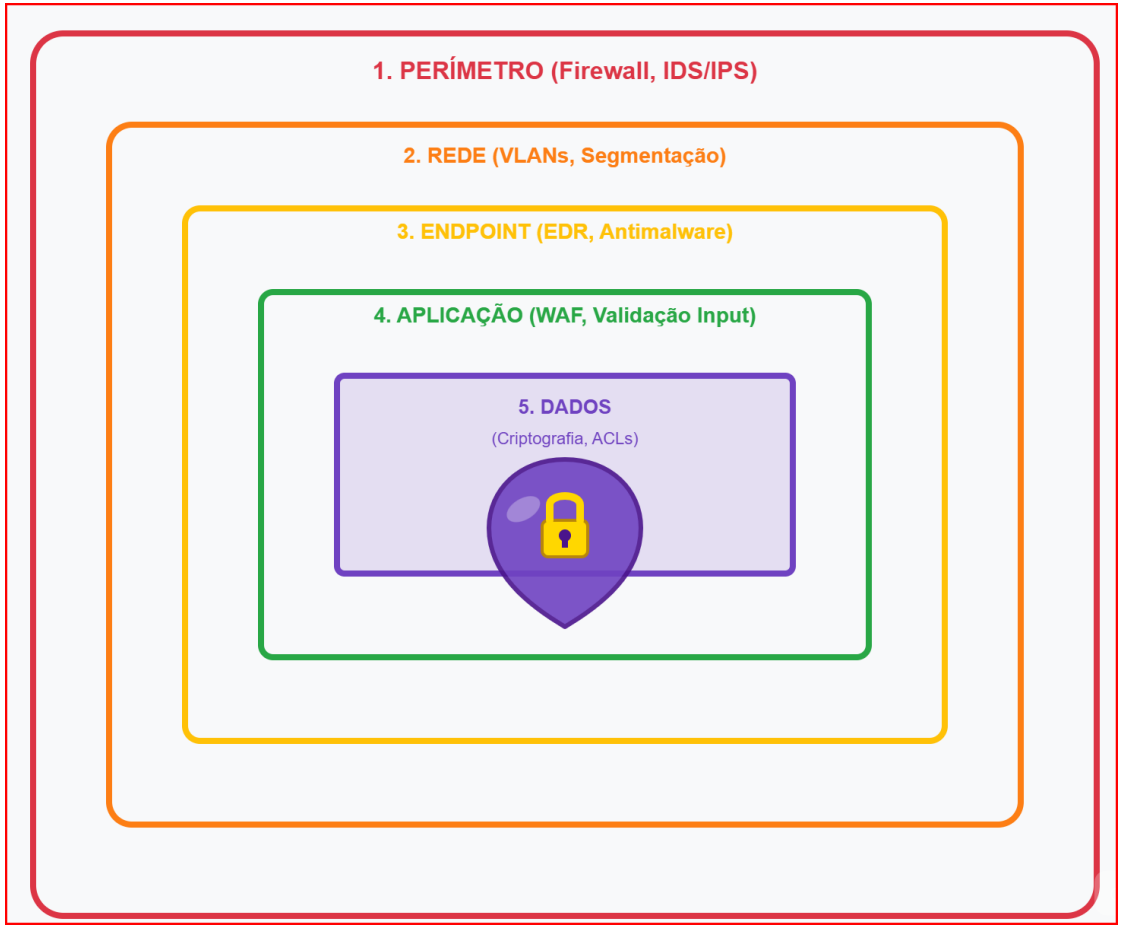
Defense in Depth (Defesa em Profundidade)

- Defense in Depth constitui uma estratégia de segurança que emprega múltiplas camadas de controles defensivos ao longo do caminho de dados, garantindo que a falha de um único mecanismo não resulte em comprometimento total;
- Inspirada em táticas militares, esta abordagem integra controles físicos, técnicos e administrativos, criando redundância protetiva;
- Cada camada – desde o perímetro externo até o núcleo dos dados – incorpora mecanismos de prevenção, detecção e resposta, dificultando a progressão de atacantes através da infraestrutura.

Defense in Depth (Defesa em Profundidade)

- **Princípio:** Nenhum controle é infalível; redundância estratégica é essencial;
- **Camadas Típicas:** Políticas → Perímetro → Rede → Endpoint → Aplicação → Dados;
- **Abordagem:** Prevenção (firewalls) + Detecção (IDS) + Resposta (contenção);
- **Vantagem:** Retardamento do atacante e redução do impacto de brechas; isoladas;
- **Implementação:** Controles complementares, não apenas repetitivos (diversidade defensiva).

Defense in Depth (Defesa em Profundidade) – Camadas de proteção



O Paradigma Zero Trust

- Zero Trust ("Nunca Confie, Sempre Verifique") representa uma ruptura epistemológica em relação aos modelos baseados em localização;
- Este framework elimina o conceito de "rede confiável", exigindo verificação contínua e estrita de identidade, dispositivo e contexto para cada solicitação de acesso, independentemente da origem;
- Desenvolvido inicialmente pelo Forrester Research e posteriormente adotado pelo NIST(1), o Zero Trust opera sob o pressuposto de que a rede já está comprometida, impondo microssegmentação e privilégio mínimo como contramedidas padrão.

---

(1) O NIST (National Institute of Standards and Technology) é o instituto federal de padronização dos Estados Unidos que desenvolve e publica diretrizes técnicas obrigatórias para agências governamentais e amplamente adotadas como referência global em segurança da informação, incluindo a norma SP 800-207 que define a arquitetura Zero Trust

O Paradigma Zero Trust

- Verificação Explícita: Autenticação e autorização contínuas para cada acesso;
- Uso de Microssegmentação: Isolamento granular entre workloads(1) e usuários;
- Privilégio Mínimo: Acesso concedido estritamente ao necessário (least privilege);
- Assunção de Brecha: Proteções projetadas assumindo que o perímetro já foi violado;
- Inspeção Profunda: Análise de tráfego cifrado(2) e comportamental (padrões de comunicação - volume, frequência, destinos) em tempo real.

———

(1) Workloads são unidades executáveis de processamento — abrangendo, entre outros, máquinas virtuais e containers — que consomem recursos computacionais e são tratadas como entidades independentes para orquestração, escalabilidade e aplicação de políticas de segurança em arquiteturas modernas.

(2) Pressupõe cenários corporativos controlados onde a organização controla os endpoints e pode instalar certificados raiz próprios

Segmentação de Rede – Conceitos Fundamentais

- A segmentação lógica de redes consiste na divisão arquitetural de uma infraestrutura IP em zonas isoladas, controladas por políticas de tráfego específicas;
- Esta prática contém o raio de explosão de incidentes de segurança, impedindo movimentação lateral de ameaças;
- A segmentação pode ser física (cabeamento separado) ou lógica (VLANs, subnets), sendo a última preferível por flexibilidade e custo-redução;
- Zonas de segurança distintas – como Management, Internal, DMZ e External – exigem controles diferenciados baseados na criticidade dos ativos hospedados.

Segmentação de Rede – Conceitos Fundamentais

- **Propósito:** Contenção de breaches(1) e redução da superfície de ataque lateral;
- **Métodos:** VLANs (camada 2), Subnetting (camada 3), Microssegmentação(2) (camada 7);
- **Zonas Típicas:** Management (administração), Internal (usuários), DMZ (serviços públicos);
- **Políticas:** Default-deny entre zonas, com regras explícitas de necessidade operacional;
- **Benefício:** Isolamento de sistemas legados e dados críticos em silos protegidos.

---

(1) Contenção de breaches é a estratégia de limitar o raio de propagação de um incidente de segurança através de barreiras arquiteturais (VLANs, subnets, firewalls), impedindo que a comprometimento de um sistema se espalhe lateralmente para ativos críticos, mesmo após a violação inicial do perímetro.

(2) Microsegmentação é a divisão granular de uma rede em segmentos de segurança extremamente pequenos (frequentemente até nível de workload, container ou processo individual), onde políticas de acesso "default-deny" são aplicadas dinamicamente baseadas em identidade e contexto, não em endereços IP estáticos, permitindo contenção precisa de ameaças mesmo dentro de uma mesma VLAN tradicional.

VLANs (Virtual Local Area Networks)

- VLANs constituem tecnologia de camada 2 do modelo OSI que permite a criação de domínios de broadcast lógicos independentes da topologia física da infraestrutura;
- Através do tagging 802.1Q, switches conseguem segregar tráfego, criando segmentos virtuais que funcionam como redes separadas;
- Esta segmentação impede que dispositivos em VLANs distintas comuniquem-se diretamente, exigindo roteamento inter-VLAN controlado por firewalls ou Layer 3 switches, o que possibilita aplicação de políticas de segurança granulares entre departamentos ou funções.

Implementação e Segurança

- Padrão: IEEE 802.1Q – tagging de quadros(1) Ethernet com identificador de VLAN (1-4094);
- Tipos: VLANs de dados, de voz (QoS)(2), de management e nativas (segurança aprimorada);
- Isolamento: Broadcast storms(3) contidos dentro de VLANs específicas;
- Roteamento: Inter-VLAN requer dispositivo de camada 3 (router ou L3 switch);
- Hardering: VLAN hopping prevention(4) (desativar trunking dinâmico, pruning(5) adequado).

_____

(1) Tagging de quadros é a técnica de inserção de um identificador de 4 bytes (campo TCI no padrão IEEE 802.1Q) no cabeçalho Ethernet para vincular um quadro a uma VLAN específica, permitindo que switches transmitam tráfego de múltiplas VLANs sobre um mesmo enlace físico (trunk) mantendo o isolamento lógico entre segmentos.

(2) VLANs de voz (Voice VLANs)são VLANs dedicadas exclusivamente ao tráfego de VoIP (Voice over IP), configuradas com QoS (Quality of Service)para garantir prioridade máxima.

(3) Broadcast storms são eventos de colapso de rede causados por uma avalanche exponencial de pacotes de broadcast/multicasting que saturam a banda e processamento dos equipamentos, geralmente decorrentes de loops de camada 2 ou ausência de segmentação (VLANs), tornando a comunicação impossível em todo o domínio de broadcast.

(4) Hopping prevention é o conjunto de contramedidas de segurança em switches que inclui a desativação do trunking dinâmico (DTP), a configuração explícita de portas como access ou trunk e o isolamento da VLAN nativa, impedindo que atacantes realizem ataques de VLAN hopping via spoofing de switches ou encapsulamento duplo de quadros 802.1Q.

(5) Pruning é a técnica de filtragem dinâmica aplicada em troncos (trunks) VLAN que suprime o encaminhamento de tráfego de broadcast/multicast para VLANs não utilizadas em determinados links, otimizando largura de banda e recursos de switching ao evitar que quadros alcancem switches desprovidos de portas ativas naquela VLAN específica.

Zona Desmilitarizada - Demilitarized Zone (DMZ)

- A Zona Desmilitarizada (DMZ) representa uma sub-rede perimetral projetada para hospedar serviços acessíveis externamente (web, email, DNS) enquanto isola a rede interna corporativa;
- Posicionada entre a Internet não-confiável e a rede privada, a DMZ opera sob premissas de máxima restrição: servidores aqui alojados não podem iniciar conexões para a rede interna, apenas responder a solicitações legitimadas;
- Comprometimentos em serviços de DMZ não garantem acesso à rede corporativa devido às regras de firewall unidirecionais e ausência de rotas diretas para segmentos internos sensíveis.

DMZ – Arquitetura e Controles

- Posicionamento: Entre firewall externo (Internet) e firewall interno (rede corporativa);
- Regra de Ouro: Nunca permitir conexões originadas na DMZ destinadas à rede interna;
- Serviços Típicos: Web servers, proxies reversos, servidores de email relay(1), DNS externos;
- Hardening: Sistemas mínimos, patching rigoroso, monitoramento intensivo (IDS/IPS);
- Variações: Triple-homed firewalls (3 interfaces)(2) ou arquitetura screened subnet dual-firewall.

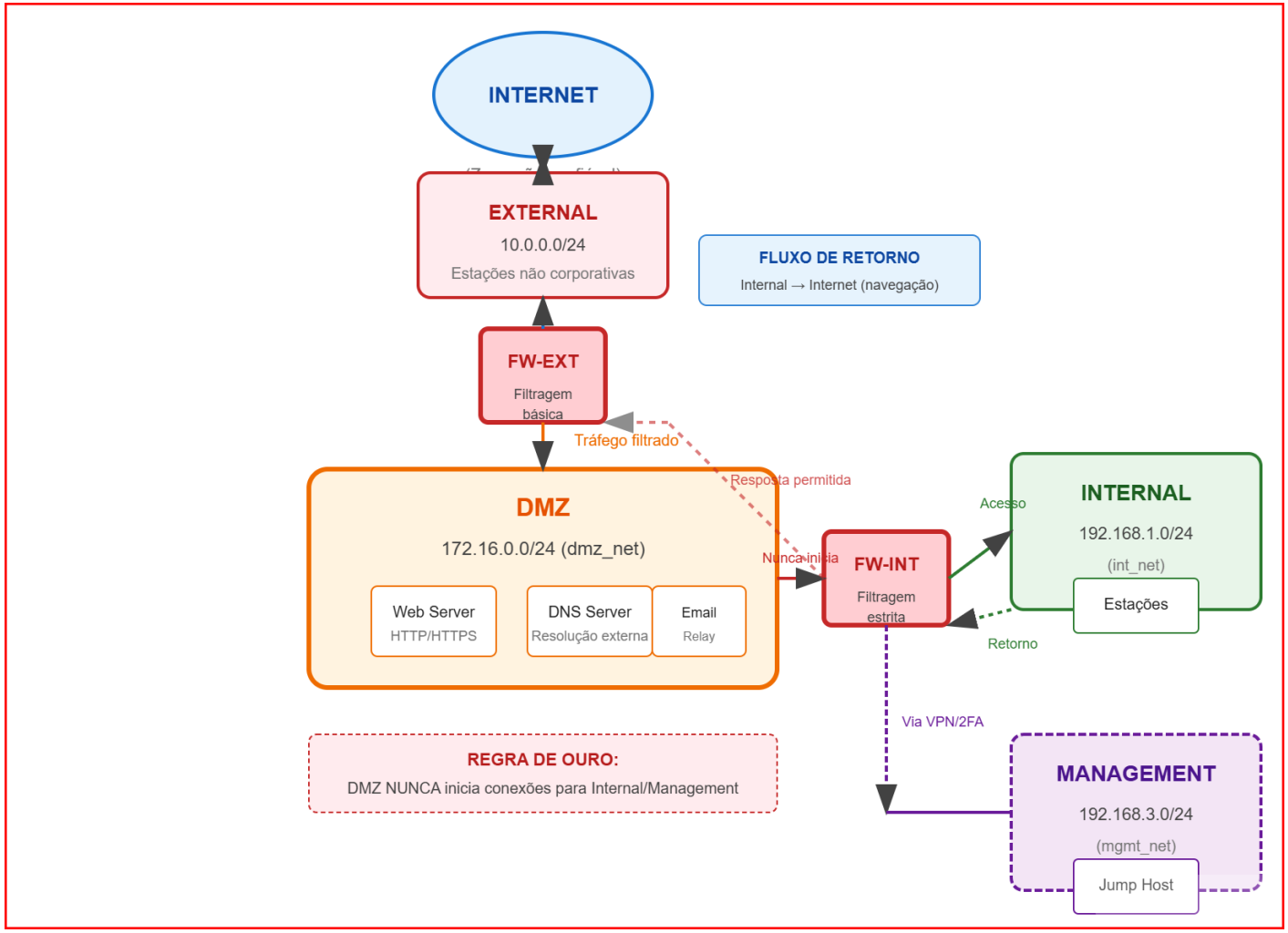
---

(1) Email relay é um servidor intermediário que recebe mensagens de um remetente e as encaminha para outro servidor de destino, funcionando como ponte entre diferentes domínios ou zonas de segurança (ex: da DMZ para a Internet ou da Internet para a rede interna), filtrando spam, malware e anonimizando a topologia interna. da Internet para a rede interna), filtrando spam, malware e anonimizando a topologia interna.

(2) Triple-homed firewalls são dispositivos de segurança equipados com três interfaces de rede distintas — tipicamente External (Internet), Internal (rede corporativa) e DMZ — permitindo a segmentação física das zonas de segurança com inspeção stateful de todo tráfego entre elas, eliminando a necessidade de dois firewalls separados em arquiteturas de menor criticidade.

(3) Arquitetura screened subnet dual-firewall é um modelo de segurança robusto onde a DMZ é isolada por dois firewalls distintos — um externo (fazendo filtragem básica de Internet para DMZ) e outro interno (fazendo filtragem rigorosa de DMZ para rede corporativa) — criando uma "sub-rede triangulada" onde comprometimento do firewall externo não garante acesso à rede interna, pois o segundo firewall permanece como barreira adicional.

Arquitetura de zonas de segurança



IDA (sólido): Internet → External → FW-EXT → DMZ → FW-INT → Internal (acesso externo aos serviços DMZ)
RETORNO (tracejado): Internal → FW-INT → DMZ → FW-EXT → External → Internet (navegação, downloads, consultas DNS)

Subnetting para Segurança

- O subnetting IP, tradicionalmente utilizado para otimização de endereçamento, adquire dimensão estratégica em arquiteturas seguras através da microssegmentação;
- Dividir blocos CIDR em subnets menores permite isolar funcionalidades críticas – como bancos de dados, sistemas ICS ou management interfaces – em broadcast domains distintos, dificultando reconhecimento de rede por atacantes. Subnets menores (ex: /30, /29 para links point-to-point(1 ou /28 para pequenos grupos de servidores) reduzem o escopo de varreduras e limitam o impacto de ARP spoofing(2) em segmentos críticos.

———

(1) Links point-to-point são conexões de rede dedicadas que interconectam exatamente dois dispositivos — como roteadores, switches ou firewalls — sem dispositivos intermediários, utilizando sub-redes /30 ou /31 (apenas 2 endereços IP utilizáveis) para maximizar a eficiência do endereçamento e isolar o tráfego entre aqueles dois pontos específicos da topologia.

(2) ARP spoofing é um ataque de envenenamento de tabela ARP onde o atacante envia respostas ARP falsas associando seu próprio endereço MAC ao IP de outro host (gateway ou vítima), interceptando tráfego de camada 3 destinado a esse IP em uma rede local compartilhada.

Subnetting – Aplicações Defensivas

- Segmentação Funcional: Cada subnet = função específica (web, app, db, mgmt);
- Máscaras Variáveis: VLSM (Variable Length Subnet Masking) para otimização hierárquica;
- Segurança: Subnets menores = menor número de hosts potencialmente comprometidos;
- Controle: ACLs e firewall rules mais específicas e gerenciáveis;
- Ocultação: Dificulta reconhecimento de topologia completa via scanning.

Zonas de Segurança e Modelagem de Ameaças

- A definição de zonas de segurança classifica segmentos de rede baseando-se no nível de confiança e criticidade dos ativos;
- Tipicamente, identificam-se quatro zonas essenciais: External (Internet não controlada), DMZ (serviços expostos controlados), Internal (usuários e recursos corporativos) e Management (infraestrutura crítica de administração);
- Cada zona possui perfis de ameaça distintos e, consequentemente, controles diferenciados;
- A zona Management, por exemplo, deve ser inacessível diretamente da DMZ ou Internet, utilizando jump hosts(1) e autenticação multifator obrigatória.

---

(1) Jump host (ou bastion host) é um servidor hardened e fortemente monitorado posicionado em uma zona de segurança intermediária (DMZ ou segmento dedicado), utilizado como ponto de entrada único e controlado para acesso administrativo à infraestrutura crítica, exigindo autenticação rigorosa e registrando todas as sessões, de modo que administradores nunca acessem diretamente sistemas sensíveis, mas sim "pulem" através deste gateway auditável.

Zonas de Segurança – Hierarquia

- External (Nível 0): Zero confiança, todo tráfego considerado hostil;
- DMZ (Nível 1): Alta exposição, hardening máximo, mínimo privilégio de saída;
- Internal (Nível 2): Usuários autenticados, acesso controlado a recursos corporativos;
- Management (Nível 3): Acesso altamente restrito, monitoramento e logging intensivos;
- Princípio: Fluxo de dados deve ser explicitamente permitido; negação implícita entre zonas.

Arquiteturas Modernas vs. Legadas

- A convergência de IT/OT(1), adoção de cloud híbrida(2) e trabalho remoto massivo demandam arquiteturas híbridas que transcendem o data center físico;
- Modelos modernos integram SASE (Secure Access Service Edge) e SSE (Security Service Edge), estendendo segmentação para endpoints dispersos geograficamente;
- Enquanto redes legadas dependem de backhauling de tráfego(3) para inspeção centralizada, arquiteturas contemporâneas distribuem políticas de segurança através de SD-WAN e zero trust network access (ZTNA)(4), mantendo princípios de segmentação independentemente da localização física ou lógica do recurso.

A convergência de IT/OT é a integração crescente entre as redes de Tecnologia da Informação (IT — sistemas corporativos, dados, cloud) e Tecnologia Operacional (OT — sistemas industriais, IoT, automação de fábricas).

Cloud híbrida é uma arquitetura de computação que combina infraestrutura on-premise (data centers corporativos privados) com serviços de nuvem pública (AWS, Azure, Google Cloud), permitindo que dados e aplicações se movam fluidamente entre ambos os ambientes — mantendo cargas sensíveis localmente por compliance ou latência, enquanto aproveita a elasticidade e custo-benefício da nuvem para demandas variáveis — exigindo segmentação de segurança consistente que transcenda o perímetro físico tradicional.

(3) Backhauling de tráfego é a prática de direcionar todo o tráfego de rede — incluindo acesso à Internet, nuvem ou comunicação entre filiais — através de um ponto centralizado (geralmente o data center corporativo principal ou HQ), onde ocorre inspeção de segurança por firewalls e proxies, antes de ser encaminhado ao destino final, criando latência e gargalos em arquiteturas modernas distribuídas.

(4) ZTNA (Zero Trust Network Access) é um modelo de acesso remoto que substitui as VPNs tradicionais, onde os usuários não obtêm acesso à rede corporativa, mas sim conectam-se diretamente a aplicações específicas validadas por identidade, contexto de dispositivo e políticas dinâmicas de segurança — eliminando a visibilidade lateral e aplicando o princípio de "nunca confie, sempre verifique" mesmo para usuários autenticados.

Arquiteturas Modernas vs. Legadas

- SASE (Secure Access Service Edge) é uma arquitetura de rede e segurança convergida que combina SD-WAN (conectividade inteligente) com serviços de segurança em nuvem, eliminando o backhauling centralizado ao aplicar políticas de segmentação e Zero Trust diretamente nos pontos de presença de borda (edge), próximos aos usuários dispersos geograficamente;
- SSE (Security Service Edge) é o componente puramente de segurança dentro do SASE — um conjunto de serviços cloud-native (ZTNA, Secure Web Gateway, Cloud Access Security Broker, sandboxing) que substitui appliances físicos de perímetro, permitindo inspeção de tráfego e acesso seguro a recursos independentemente da localização do usuário ou workload;
- Enquanto VLANs e firewalls físicos segmentam o data center, SASE/SSE estendem essa segmentação lógica para qualquer lugar — casa do funcionário, café, filial remota — mantendo as políticas de Zero Trust sem depender do perímetro físico da empresa.

Arquitetura Legada	SASE/SSE Moderno
Backhauling para HQ → depois para Internet/Cloud	Acesso direto local à edge security node
Segurança centralizada em appliances físicos	Segurança distribuída como serviço (cloud)
VPN tradicional (túnel para rede corporativa)	ZTNA (accesso a aplicação específica, não à rede)

Considerações sobre Implementação

- A implementação de arquiteturas segmentadas exige balanceamento entre segurança, performance e operabilidade;
- Segmentação excessivamente granular pode introduzir complexidade administrativa insustentável, latência em roteamentos inter-subnet e dificuldades em troubleshooting;
- Recomenda-se adoção gradual: inicia-se com DMZ e VLANs de management, expandindo-se para microssegmentação conforme maturidade da equipe;
- Documentação rigorosa de fluxos de dados (data flow diagrams) é pré-requisito indispensável para definição de políticas de firewall eficazes e evitar over-permissiveness por desconhecimento das dependências de aplicações.

Boas Práticas de Implementação

- Faseamento: Priorizar segmentação de ativos críticos e expostos (crown jewels);
- Documentação: Mapeamento completo de fluxos de dados antes de implementar regras;
- Automação: Infraestrutura como Código (IaC)[1] para consistência em regras de segmentação;
- Monitoramento: NetFlow/sFlow entre zonas para detectar anomalias de comunicação;
- Revisão: Auditoria periódica de regras de firewall e validação de necessidade business.

---

(1) Infraestrutura como Código (IaC) é a prática de gerenciar e provisionar recursos de infraestrutura — servidores, redes, firewalls, VLANs — através de arquivos de configuração versionáveis e automatizáveis (ex: Terraform, Ansible, CloudFormation), garantindo consistência, auditoria e reprodutibilidade das políticas de segurança em ambientes on-premise, cloud ou híbridos.

Caso de Uso: Arquitetura Multi-Camadas

- Um e-commerce típico ilustra a aplicação prática destes conceitos: a camada de apresentação (web servers) reside na DMZ, comunicando-se apenas via HTTPS com clientes e via APIs restritas com a camada de aplicação em VLAN interna distinta;
- A camada de dados (banco de dados) habita subnet adicional, acessível exclusivamente por ports específicos dos servidores de aplicação;
- A zona de management isola backups, logs e acesso administrativo;
- Comprometimento do web server não propaga lateralmente devido à ausência de rotas diretas para a subnet de banco de dados, exemplificando Defense in Depth através de segmentação estratégica.

Evolução Arquitetural

- Legado: Hub-and-spoke[1], backhauling centralizado, VPNs de acesso remoto tradicionais
- Moderno: Mesh[2] distribuído, inspeção local (edge computing), ZTNA
- Convergência: Integração de políticas on-premise e cloud-native (hybrid cloud)[3]
- Elasticidade: Segmentação dinâmica baseada em identidade, não endereço IP estático
- Desafio: Complexidade aumentada exige automação e orquestração (SDN)

---

(1) Hub-and-spoke é uma topologia de rede WAN tradicional onde todas as filiais (spokes) se conectam exclusivamente a um site centralizado (hub) — geralmente o data center corporativo ou matriz — para acessar a Internet, serviços de nuvem ou comunicar-se entre si, forçando o backhauling de tráfego e criando latência, gargalos e ponto único de falha, sendo substituída por arquiteturas mesh/SASE em redes modernas;

(2) Mesh é uma topologia de rede distribuída onde os nós (filiais, data centers, endpoints) interconectam-se diretamente entre si formando múltiplos caminhos alternativos, permitindo comunicação ponto-a-ponto sem backhauling por um hub centralizado, oferecendo redundância automática e latência reduzida — característica fundamental das arquiteturas SD-WAN e SASE modernas.

(3) On-premise refere-se a infraestrutura de TI fisicamente instalada e operada nos data centers corporativos próprios, enquanto cloud-native descreve aplicações arquitetadas especificamente para operar em ambientes de nuvem pública ou privada, utilizando contêineres, microserviços e orquestração dinâmica, sem dependência de hardware local.

Análise de Caso

- Camada Web (DMZ): Apache/Nginx expostos, apenas portas 80/443 abertas externamente
- Camada Aplicação: VLAN interna, comunicação encriptada com web servers, sem acesso Internet
- Camada Dados: Subnet isolada, SQL ports restritos aos IPs dos app servers
- Management: VPN obrigatória, jump host, 2FA[1], logging de todas as sessões administrativas
- Resultado: Movimentação lateral impedida; atacante em DMZ não alcança dados sensíveis

———

(2) 2FA (Two-Factor Authentication, ou Autenticação de Dois Fatores) é um mecanismo de segurança que exige duas categorias distintas de evidência para verificação de identidade — algo que o usuário sabe (senha), algo que possui (token, smartphone) ou algo que é (biometria) — impedindo acesso não autorizado mesmo que uma das credenciais seja comprometida, sendo obrigatório para acesso à zona de Management.

Síntese e Transição para Prática

- Os princípios teóricos aqui apresentados – transição de perímetro fixo para Zero Trust, segmentação lógica via VLANs e subnets, e contenção através de DMZs – constituem a base para a atividade prática subsequente. A implementação destas arquiteturas em ambientes virtualizados permite validação controlada de políticas de segurança sem risco à infraestrutura produtiva. A sessão prática demonstrará como estas abstrações teóricas materializam-se em regras de firewall, interfaces de rede e rotas estáticas em ambiente laboratorial.

Arquivos da disciplina

- Link para aGoogle Drive com os arquivos da disciplina:
  - https://drive.google.com/drive/folders/1KuGQgeDWl5RLBZntXmgqlx6NkJnvQx_i?usp=sharing